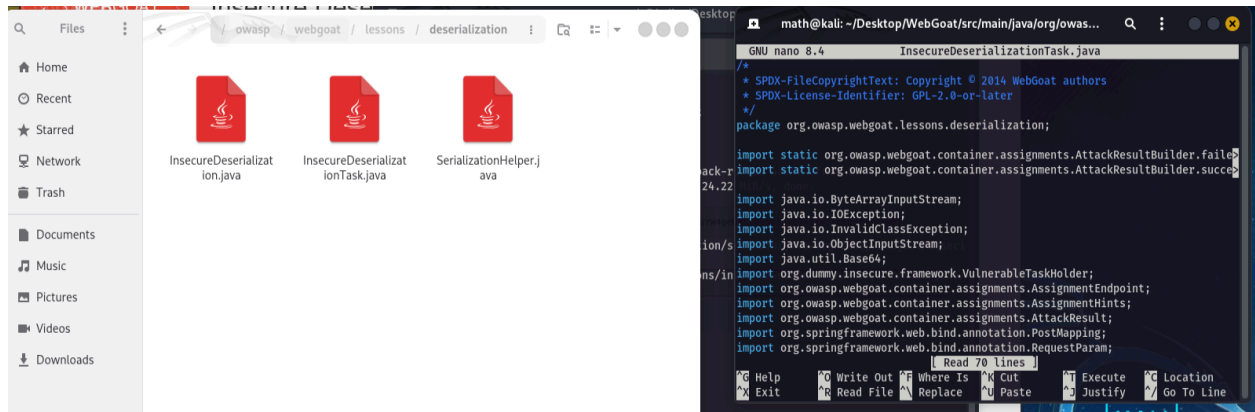


Navigate to

WebGoat/webgoat-lessons/insecure-deserialization/src/main/java/org/owasp/webgoat/deserialization

And locate the task file



Locate the endpoint in that file

```
try (ObjectInputStream ois =
    new ObjectInputStream(new ByteArrayInputStream(Base64.getDecoder().decode(b64token)))) {
    before = System.currentTimeMillis();
    Object o = ois.readObject();
    if (!(o instanceof VulnerableTaskHolder)) {
        if (o instanceof String) {
            return failed(this).feedback("insecure-deserialization.stringobject").build();
        }
        return failed(this).feedback("insecure-deserialization.wrongobject").build();
    }
    after = System.currentTimeMillis();
} catch (InvalidClassException e) {
    return failed(this).feedback("insecure-deserialization.invalidversion").build();
} catch (IllegalArgumentException e) {
    return failed(this).feedback("insecure-deserialization.expired").build();
} catch (Exception e) {
    return failed(this).feedback("insecure-deserialization.invalidversion").build();
}

delay = (int) (after - before);
if (delay > 7000) {
    return failed(this).build();
}
if (delay < 3000) {
    return failed(this).build();
}
return success(this).build();
}
```

Compile

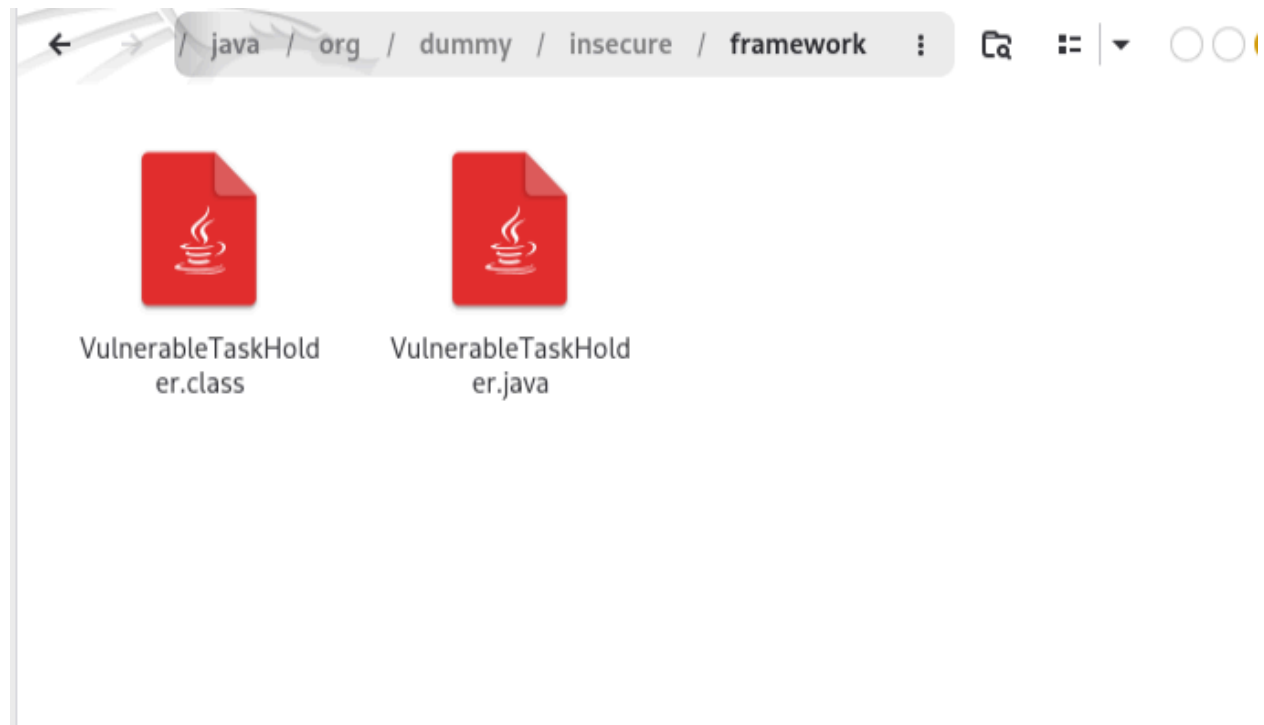
WebGoat/webgoat-lessons/insecure-deserialization/src/main/java/org/dummy/insecure/framework/VulnerableTaskHolder.java

There are errors so remove the unnecessary imports and [log.info](#) lines

Try to compile again, ignore these notes

```
(math@kali)-[~/.../org/dummy/insecure/framework]
$ javac VulnerableTaskHolder.java
Note: VulnerableTaskHolder.java uses or overrides a deprecated API.
Note: Recompile with -Xlint:deprecation for details.
```

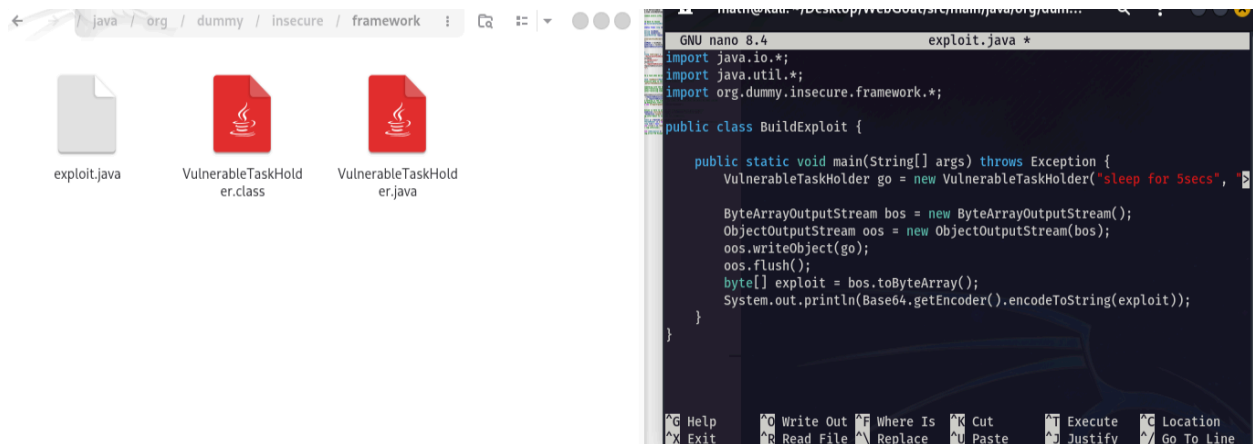
Now we have a .class file



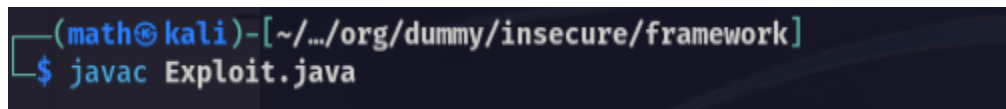
Get the exploit from:

<https://github.com/WebGoat/WebGoat/wiki/Main-Exploits#insecure-deserialization-lesson-5-exercise>

Create a file for the exploit



Compile the exploit

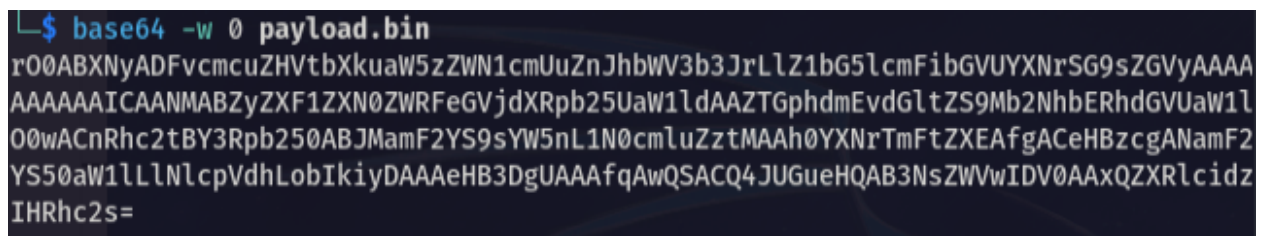


Run it



payload.bin is created,

Get the Base64 of it



Paste

“r00ABXNyADFvcmcuZHVtbXkuaW5zZW50cmUuZnJhbWV3b3JrLlZ1bG5lcmFibGVUYXNrSG9sZGVyAAAAAAAAAICAANMABZyZXF1ZXN0ZWRFcGVjdXRpb25UaW1ldAAZTGphdmEvdGltZS9Mb2NhbnRhdGVUaW1lO0wACnRhc2tBY3Rpb250ABJMamF2YS9sYW5nL1N0cmLuZztMAAh0YXNrTmFtZXEAfgACeHBzcgANamF2YS50aW1lLlNlcpVdhLobIkiyDAAAeHB3DgUAAAfqAwQSACQ4JUGueHQAAB3NsZWVwIDV0AAxQZXRLcidzIHRhc2s=”

Into the token input and the lab is complete

Insecure Deserialization



Reset lesson

➕ 1 2 3 4 5 ➕

Let's try

The following input box receives a serialized object (a string) and it deserializes it.

r00ABXQAVk1mIHlvdSBkZXNlcm1hbG16ZSBtZSBkb3duLCBjIHNoYWxsIGJlY29tZSBtb3JlIHVud2VyZnVsIHRoYW4gew91IGNhb1Bwb3NzaWJseSBpbWFnaw5l

Try to change this serialized object in order to delay the page response for exactly 5 seconds.



/0AAxQZXRLcidzIHRhc2s=

Submit

Congratulations. You have successfully completed the assignment.